

AUDIT DE CONFORMITÉ RGPD

Règlement Général sur la Protection des Données

TechSud SAS — Sécurisation du SI — Projet AEGIS

Réf. TS-2026-RGPD-001 · Classification : CONFIDENTIEL PÉDAGOGIQUE

Responsable de traitement	TechSud SAS — Marc FERRAND, DSI
Auditeur RGPD	Gyessi — Responsable Conformité, Projet AEGIS
Référentiel	RGPD (UE) 2016/679 — Articles 32, 33, 34
Périmètre	Infrastructure SI TechSud — Suite à l'incident du 18/04/2026
Date de l'audit	Mai 2026
École	IPSSI — Promotion BTC1 — 2026

Document fictif produit à des fins exclusivement pédagogiques — Ne pas diffuser

1. Contexte juridique et périmètre de l'audit

TechSud SAS, en tant que responsable de traitement au sens de l'article 4 du RGPD, collecte et traite des données à caractère personnel dans le cadre de son activité de distribution B2B : données clients, prospects, collaborateurs (47 personnes).

L'incident du 18 avril 2026 constitue une violation de données personnelles au sens de l'article 4§12 du RGPD : accès non autorisé à des données traitées par le serveur SRV-PROD-01, potentiellement compromise pendant plusieurs heures. Cet audit évalue la conformité des mesures techniques mises en place au regard des obligations réglementaires.

1.1 Textes de référence

- Règlement (UE) 2016/679 du 27 avril 2016 (RGPD)
- Article 32 — Sécurité du traitement
- Article 33 — Notification de violations à l'autorité de contrôle (CNIL)
- Article 34 — Communication de violations aux personnes concernées
- Lignes directrices CNIL — Sécurité des données personnelles (2023)

2. Violations de données constatées

L'incident du 18 avril 2026 constitue une violation de données au sens du RGPD. Le tableau suivant synthétise les violations identifiées, leur nature et leur niveau de gravité selon les critères ENISA.

Nature de la violation	Type	Données concernées	Gravité
Accès non autorisé via compte deploy (Tor)	Confidentialité	Données ERP, clients, fichiers	ÉLEVÉE
Webshell actif pendant plusieurs heures	Confidentialité + Intégrité	Données serveur web, formulaires	ÉLEVÉE
Logs effacés sur 36h (17/04 → 18/04)	Disponibilité + Traçabilité	Journaux d'accès	ÉLEVÉE
Processus malveillant kworker — beacon C2	Confidentialité	Toutes données en mémoire	CRITIQUE
Binaire ELF persistant dans /tmp	Intégrité + Disponibilité	Système d'exploitation	ÉLEVÉE
Mots de passe faibles (prenom2024)	Confidentialité	Comptes utilisateurs	ÉLEVÉE
MariaDB potentiellement exposé WAN	Confidentialité	Base de données clients/commandes	CRITIQUE

2.1 Obligation de notification — Article 33

L'article 33 du RGPD impose au responsable de traitement de notifier toute violation de données à l'autorité de contrôle compétente (CNIL en France) dans un délai de 72 heures après en avoir eu connaissance, sauf si la violation est peu susceptible d'engendrer un risque pour les droits et libertés des personnes.

Critère	Analyse	Obligation
Violation avérée	Accès non autorisé confirmé — logs SSH + webshell + IOC	OUI
Risque pour personnes	Données clients/commandes potentiellement consultées	OUI
Délai de notification	72h à compter de la détection (19/04 00h23)	À effectuer dans les délais

3. Conformité Article 32 — Sécurité du traitement

L'article 32 impose la mise en œuvre de mesures techniques et organisationnelles appropriées pour garantir un niveau de sécurité adapté au risque, notamment : la pseudonymisation et le chiffrement, les moyens permettant de garantir la confidentialité, l'intégrité, la disponibilité et la résilience des systèmes.

Mesure Art. 32	État initial	État final	Moyen technique
Contrôle d'accès	Non conforme	Conforme	SSH par clé Ed25519, PermitRootLogin no
Chiffrement des communications	Non conforme	Conforme	SSH TLS — PasswordAuthentication no
Authentification forte	Non conforme	Conforme	Clé Ed25519 + MaxAuthTries 3
Filtrage réseau	Non conforme	Conforme	UFW default deny, seul port 2222
Détection d'intrusion	Absent	Partiel	Fail2ban — SIEM recommandé
Journalisation des accès	Non centralisée	Partiel	Logs SSH — centralisation recommandée
Moindre privilège	Non conforme	Conforme	Désactivation comptes inutiles, chmod 700
Mises à jour de sécurité	En retard	Conforme	apt full-upgrade effectué
Protection des sauvegardes	Non testée	Non conforme	NAS-01 — test et backup hors-site requis
Chiffrement des données au repos	Absent	Non évalué	LUKS recommandé pour /var/lib/mysql

4. Analyse des risques RGPD

L'analyse des risques suit la méthode EBIOS Risk Manager adaptée au contexte de TechSud. Pour chaque scénario, la probabilité et l'impact sont évalués sur une échelle de 1 (faible) à 4 (critique).

Scénario de risque	Prob. initiale	Impact	Prob. finale	Traitement
Brute-force SSH → compromission	4 (Critique)	4 (Critique)	1 (Faible)	Port 2222 + Fail2ban + clé
Upload webshell → exécution code	4 (Critique)	4 (Critique)	2 (Moyen)	Détection IOC — correctif applicatif requis
Accès DB clients par port 3306 WAN	3 (Élevée)	4 (Critique)	2 (Moyen)	Fermeture port WAN dans pfSense requis
Fuite données collaborateurs	3 (Élevée)	3 (Élevée)	1 (Faible)	Accès restreint, chmod 700
Ransomware → perte données	2 (Moyenne)	4 (Critique)	2 (Moyenne)	Backup NAS non testé — plan requis
Non-détection d'intrusion prolongée	3 (Élevée)	4 (Critique)	2 (Moyen)	Fail2ban — SIEM requis pour détection avancée
Credential stuffing sur comptes web	3 (Élevée)	3 (Élevée)	2 (Moyen)	Politique mots de passe à imposer

5. Privacy by Design et Privacy by Default

L'article 25 du RGPD impose l'intégration de la protection des données dès la conception (Privacy by Design) et par défaut (Privacy by Default). Les mesures appliquées dans le projet AEGIS respectent ces principes.

Principe	Application dans le projet AEGIS
Minimisation des données	Désactivation des services inutiles — réduction de la surface de collecte
Moindre privilège	PermitRootLogin no, chmod 700, désactivation shell postgres
Sécurité par défaut	UFW default deny — aucun accès sans autorisation explicite
Intégration de la sécurité dès la conception	Authentification par clé dès l'installation SSH
Transparence	Journalisation de tous les accès SSH (auth.log)
Responsabilisation (Accountability)	Script d'audit automatisé pour traçabilité continue

6. Recommandations de mise en conformité

6.1 Actions immédiates — Obligations légales

Les actions suivantes relèvent d'obligations légales directes au titre du RGPD. Leur non-réalisation expose TechSud à des sanctions administratives de la CNIL.

Notifier la CNIL (Art. 33) dans les 72h suivant la détection	Obligatoire	URGENT
Évaluer si les personnes concernées doivent être notifiées (Art. 34)	Obligatoire si risque élevé	URGENT
Documenter la violation dans le registre des incidents (Art. 33§5)	Obligatoire	Immédiat
Mettre à jour le registre des traitements (Art. 30)	Obligatoire	Court terme

6.2 Actions techniques complémentaires

Mesure	Objectif	Article RGPD
Chiffrement au repos (LUKS)	Protéger /var/lib/mysql et les partitions de données	Art. 32
SIEM (Wazuh/ELK)	Centraliser les logs — détecter et tracer tous les accès	Art. 32 + 33
Politique mots de passe	Complexité imposée, rotation trimestrielle, MFA recommandé	Art. 32
Validation MIME stricte	Bloquer l'upload de fichiers non autorisés sur SRV-WEB-01	Art. 32
Backup hors-site (3-2-1)	Garantir la disponibilité des données (3 copies, 2 supports, 1 hors-site)	Art. 32
Tests d'intrusion annuels	Évaluer régulièrement le niveau de sécurité	Art. 32§1d

6.3 Actions organisationnelles

- Désigner un DPO (Délégué à la Protection des Données) interne ou externe
- Organiser des formations annuelles RGPD pour les collaborateurs
- Établir et maintenir un registre des traitements complet (Art. 30)
- Rédiger une politique de sécurité formelle et la diffuser à tous les collaborateurs
- Définir et tester un Plan de Continuité d'Activité (PCA) incluant les données personnelles
- Encadrer contractuellement les sous-traitants (clause RGPD dans les contrats)

7. Tableau de bord de conformité RGPD

Article RGPD	Obligation	Mesure technique déployée	Statut
Art. 25 — Privacy by Design	Sécurité intégrée dès la conception	Principe du moindre privilège — default deny	CONFORME
Art. 32 — Confidentialité	Accès restreint aux données personnelles	SSH par clé, PermitRootLogin no, UFW	CONFORME
Art. 32 — Intégrité	Protection contre modification non autorisée	Fail2ban, chmod 700, services désactivés	CONFORME
Art. 32 — Disponibilité	Garantie d'accès aux données	MàJ système — backup NAS non testé	PARTIEL
Art. 32 — Résilience	Capacité à restaurer les données	Plan de backup hors-site à définir	NON CONFORME
Art. 33 — Notification CNIL	Notification dans les 72h	Logs SSH tracés — notification à initier	À RÉALISER
Art. 34 — Communication	Information des personnes si risque élevé	Évaluation du risque résiduel requise	À ÉVALUER
Art. 30 — Registre	Tenir un registre des traitements	Documentation à mettre à jour	PARTIEL

8. Conclusion

L'audit de conformité RGPD conduit dans le cadre du projet AEGIS révèle que TechSud présentait, avant l'incident, de graves lacunes dans sa mise en conformité au Règlement Général sur la Protection des Données, notamment en matière de sécurité technique (Article 32) et d'absence de politique de gestion des incidents.

Les mesures déployées dans le cadre du lab AEGIS — durcissement SSH, pare-feu UFW, Fail2ban, gestion des comptes — adressent directement les obligations de l'Article 32. Cependant, des actions complémentaires demeurent nécessaires : notification CNIL (Art. 33), chiffrement au repos, politique de sauvegarde testée et désignation d'un DPO.

La mise en conformité RGPD n'est pas un état ponctuel mais un processus continu. Le script d'audit automatisé `audit_ssh.py` constitue un premier outil pour maintenir dans le temps le niveau de conformité technique, en complément d'un SIEM et d'une politique organisationnelle formalisée.

Document fictif produit à des fins exclusivement pédagogiques — IPSSI BTC1 2026